

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC NHA TRANG
KHOA CÔNG NGHỆ THÔNG TIN



ĐỒ ÁN TỐT NGHIỆP ĐẠI HỌC

**THIẾT KẾ VÀ TRIỂN KHAI HỆ THỐNG ZERO
TRUST SOFTWARE SUPPLY CHAIN TRÊN
KUBERNETES THEO CHUẨN SLSA LEVEL 3**

Sinh viên thực hiện : Họ và Tên Sinh Viên

Ngành : Công nghệ thông tin

Giảng viên hướng dẫn : TS. Tên Giảng Viên

Khánh Hòa - 2026

Lời cam đoan

Tôi cam đoan đây là công trình do tôi tự thực hiện dưới sự hướng dẫn của TS. Tên Giảng Viên. Các nội dung nghiên cứu, số liệu và kết quả là trung thực. Các số liệu, công trình sử dụng của tác giả khác đều được trích dẫn nguồn gốc rõ ràng. Tất cả phần mềm, mã nguồn được sử dụng trong đồ án này đều có giấy phép mã nguồn mở.

Nếu phát hiện có bất kỳ sự gian lận nào, tôi xin chịu hoàn toàn trách nhiệm.

Họ và Tên Sinh Viên

Lời cảm ơn

Lời cảm ơn sẽ được bổ sung sau.

Tóm tắt

Đồ án nghiên cứu và triển khai hệ thống Zero Trust Software Supply Chain cho Kubernetes theo chuẩn SLSA Level 3, nhằm đảm bảo an toàn cho quy trình build và triển khai container image. Hệ thống bao gồm pipeline CI/CD tự động tạo provenance và ký số container image, quản lý SBOM, và Kubernetes Admission Controller kiểm soát việc triển khai container theo mô hình Zero Trust. Kết quả thực nghiệm cho thấy hệ thống có khả năng ngăn chặn hiệu quả các kịch bản tấn công giả mạo và chèn mã độc trong chuỗi cung ứng phần mềm.

Từ khóa: Zero Trust, Software Supply Chain, SLSA, Kubernetes, Container Security, Sigstore, Provenance, SBOM.

Mục lục

1	Tổng quan đề tài	1
1.1	Bối cảnh và lý do chọn đề tài	1
1.2	Mục tiêu nghiên cứu	1
1.3	Đối tượng và phạm vi nghiên cứu	2
1.3.1	Đối tượng nghiên cứu	2
1.3.2	Phạm vi nghiên cứu	2
1.3.3	Giới hạn	2
1.4	Bố cục đồ án	3
2	Cơ sở lý thuyết	4
2.1	Software Supply Chain và các rủi ro bảo mật	5
2.1.1	Định nghĩa chuỗi cung ứng phần mềm	5
2.1.2	Các vector tấn công phổ biến	5
2.1.3	Các cuộc tấn công tiêu biểu	5
2.2	Mô hình bảo mật Zero Trust	5
2.2.1	Khái niệm Zero Trust	5
2.2.2	Áp dụng Zero Trust vào SDLC	5
2.3	Khung tiêu chuẩn SLSA	5
2.3.1	Tổng quan về SLSA	5
2.3.2	Build Track – Các cấp độ bảo mật	5
2.3.3	Source Track	5
2.3.4	Threat Model theo SLSA	5
2.3.5	Mô hình xây dựng và Provenance Schema	5
2.4	Kubernetes và Container Security	5
2.4.1	Kiến trúc Kubernetes	5
2.4.2	Admission Controllers trong Kubernetes	5
2.4.3	OCI Image Format và Image Security	5
2.5	Hệ sinh thái công cụ liên quan	5
2.5.1	Sigstore – Hệ sinh thái ký số	5

2.5.2	SBOM – Software Bill of Materials	5
2.5.3	Policy Engines	5
3	Phân tích và Thiết kế hệ thống	6
3.1	Kiến trúc tổng thể	6
3.2	Thiết kế giai đoạn Source – Quản lý mã nguồn	6
3.3	Thiết kế giai đoạn Build – Đáp ứng SLSA Level 3	6
3.3.1	Môi trường Build phù du và cô lập	6
3.3.2	Tạo Provenance	6
3.3.3	Tạo SBOM	6
3.3.4	Ký số – Digital Signing	6
3.4	Thiết kế giai đoạn Deploy – Zero Trust trên Kubernetes	6
3.4.1	Kiến trúc Admission Controller	6
3.4.2	Thiết kế Policy Rules	6
3.5	Thiết kế kịch bản kiểm thử và tấn công mô phỏng	6
4	Triển khai và Đánh giá	7
4.1	Môi trường triển khai	7
4.2	Triển khai Pipeline CI/CD	7
4.2.1	Sample Application	7
4.2.2	Cấu hình CI Pipeline	7
4.2.3	Ký số và Tạo Attestation	7
4.3	Triển khai Policy Engine trên Kubernetes	7
4.3.1	Cài đặt Kyverno	7
4.3.2	Cấu hình ClusterPolicy	7
4.4	Kết quả kiểm thử các kịch bản	7
4.4.1	Kịch bản Happy Path	7
4.4.2	Kịch bản tấn công - Attack Scenarios	7
4.5	Đánh giá hiệu năng	7
4.6	Đối chiếu với tiêu chuẩn SLSA Level 3	7
5	Kết luận và Hướng phát triển	8
5.1	Kết luận	8
5.2	Khó khăn gặp phải	8
5.3	Hướng phát triển tương lai	8

Danh sách bảng

Danh sách hình vẽ

Chương 1

Tổng quan đề tài

1.1 Bối cảnh và lý do chọn đề tài

Trong bối cảnh công nghệ thông tin hiện đại, an ninh chuỗi cung ứng phần mềm (Software Supply Chain Security) đã trở thành một trong những ưu tiên chiến lược cấp bách nhất. Các cuộc tấn công chấn động như SolarWinds (2020), Codecov (2021), Log4Shell (2021) và xz-utils (2024) đã phơi bày một thực tế: tin tặc không chỉ nhắm vào ứng dụng trực tiếp mà đang khai thác các điểm yếu trong hệ thống hạ tầng xây dựng và các thư viện mã nguồn mở phụ thuộc.

Mô hình bảo mật truyền thống – chỉ bảo vệ vòng ngoài (perimeter security) – đã không còn đủ khả năng đối phó với các vector tấn công tinh vi nhắm vào toàn bộ vòng đời phát triển phần mềm. Mô hình Zero Trust với nguyên tắc “Never trust, always verify” cung cấp một cách tiếp cận phù hợp hơn, yêu cầu xác minh mọi thành phần tại mọi giai đoạn.

Khung tiêu chuẩn SLSA (Supply-chain Levels for Software Artifacts) – được phát triển bởi OpenSSF dựa trên các thực tiễn bảo mật của Google – cung cấp một mô hình trưởng thành với các cấp độ bảo mật tăng dần, giúp tổ chức đánh giá và cải thiện tính toàn vẹn chuỗi cung ứng một cách có hệ thống.

Kubernetes, với vai trò là nền tảng orchestration container phổ biến nhất hiện nay, cung cấp cơ chế Admission Controller cho phép kiểm soát chặt chẽ việc triển khai container – tạo điều kiện lý tưởng để hiện thực hóa mô hình Zero Trust tại điểm cuối của chuỗi cung ứng.

1.2 Mục tiêu nghiên cứu

Các mục tiêu chính của đề án bao gồm:

- Nghiên cứu các công nghệ và tiêu chuẩn liên quan đến DevSecOps, Zero Trust Architecture và Software Supply Chain Security.
- Xây dựng pipeline CI/CD theo chuẩn SLSA Level 3, đảm bảo tính toàn vẹn và truy vết nguồn gốc của container image.
- Áp dụng cơ chế ký số container image và tạo các bằng chứng xác thực (provenance, attestation).
- Tạo và quản lý SBOM (Software Bill of Materials), thực hiện quét và đánh giá lỗ hổng bảo mật.
- Triển khai Kubernetes Admission Controller để kiểm soát việc triển khai container theo mô hình Zero Trust.
- Thực nghiệm, mô phỏng các kịch bản tấn công và đánh giá hiệu quả của giải pháp.

1.3 Đối tượng và phạm vi nghiên cứu

1.3.1 Đối tượng nghiên cứu

- Quy trình CI/CD an toàn theo chuẩn SLSA Level 3
- Cơ chế ký số và xác thực container image (Sigstore/Cosign)
- Kubernetes Admission Controller và Policy Engine
- Software Bill of Materials (SBOM) và quét lỗ hổng bảo mật

1.3.2 Phạm vi nghiên cứu

- **Nền tảng core:** Kubernetes (triển khai local cluster hoặc cloud)
- **CI/CD:** GitHub Actions hoặc Tekton Pipelines (tùy theo đánh giá khả thi)
- **Signing & Attestation:** Sigstore ecosystem (Cosign, Fulcio, Rekor)
- **Policy Engine:** Kyverno hoặc tương đương
- **SBOM:** Syft hoặc Trivy (chuẩn SPDX/CycloneDX)

1.3.3 Giới hạn

- Đề án tập trung vào khía cạnh bảo mật chuỗi cung ứng, không đi sâu vào phát triển ứng dụng.

- Sample application chỉ mang tính minh họa, ưu tiên tính đơn giản.
- Không bao gồm: runtime security monitoring, network policies, hermetic builds (SLSA L4).

1.4 Bố cục đề án

Đề án gồm các phần như sau:

- **Chương 1:** Tổng quan đề tài – Trình bày bối cảnh, mục tiêu, phạm vi nghiên cứu.
- **Chương 2:** Cơ sở lý thuyết – Trình bày nền tảng kiến thức về Supply Chain Security, Zero Trust, SLSA, Kubernetes.
- **Chương 3:** Phân tích và Thiết kế hệ thống – Kiến trúc tổng thể và thiết kế chi tiết từng giai đoạn.
- **Chương 4:** Triển khai và Đánh giá – Cài đặt, cấu hình, kịch bản kiểm thử, đánh giá kết quả.
- **Chương 5:** Kết luận và Hướng phát triển.

Chương 2

Cơ sở lý thuyết

2.1 Software Supply Chain và các rủi ro bảo mật

2.1.1 Định nghĩa chuỗi cung ứng phần mềm

2.1.2 Các vector tấn công phổ biến

2.1.3 Các cuộc tấn công tiêu biểu

2.2 Mô hình bảo mật Zero Trust

2.2.1 Khái niệm Zero Trust

2.2.2 Áp dụng Zero Trust vào SDLC

2.3 Khung tiêu chuẩn SLSA

2.3.1 Tổng quan về SLSA

2.3.2 Build Track – Các cấp độ bảo mật

2.3.3 Source Track

2.3.4 Threat Model theo SLSA

2.3.5 Mô hình xây dựng và Provenance Schema

2.4 Kubernetes và Container Security

2.4.1 Kiến trúc Kubernetes

2.4.2 Admission Controllers trong Kubernetes

2.4.3 OCI Image Format và Image Security

Chương 3

Phân tích và Thiết kế hệ thống

3.1 Kiến trúc tổng thể

Kiến trúc hệ thống được thiết kế theo mô hình phân lớp (layered architecture), trong đó mỗi lớp có thể thay thế công cụ cụ thể mà không ảnh hưởng đến các lớp còn lại. Kubernetes đóng vai trò là nền tảng core xuyên suốt hệ thống.

3.2 Thiết kế giai đoạn Source – Quản lý mã nguồn

3.3 Thiết kế giai đoạn Build – Đáp ứng SLSA Level 3

3.3.1 Môi trường Build phù du và cô lập

3.3.2 Tạo Provenance

3.3.3 Tạo SBOM

3.3.4 Ký số – Digital Signing

3.4 Thiết kế giai đoạn Deploy – Zero Trust trên Kubernetes

3.4.1 Kiến trúc Admission Controller

3.4.2 Thiết kế Policy Rules

3.5 Thiết kế kịch bản kiểm thử và tấn công mô phỏng

Chương 4

Triển khai và Đánh giá

4.1 Môi trường triển khai

4.2 Triển khai Pipeline CI/CD

4.2.1 Sample Application

4.2.2 Cấu hình CI Pipeline

4.2.3 Ký số và Tạo Attestation

4.3 Triển khai Policy Engine trên Kubernetes

4.3.1 Cài đặt Kyverno

4.3.2 Cấu hình ClusterPolicy

4.4 Kết quả kiểm thử các kịch bản

4.4.1 Kịch bản Happy Path

4.4.2 Kịch bản tấn công - Attack Scenarios

4.5 Đánh giá hiệu năng

4.6 Đối chiếu với tiêu chuẩn SLSA Level 3

Chương 5

Kết luận và Hướng phát triển

5.1 Kết luận

5.2 Khó khăn gặp phải

5.3 Hướng phát triển tương lai

Tài liệu tham khảo